



Seguridad — CasesiPhone

Este documento resume las medidas de seguridad implementadas y cómo activar la protección anti-DDoS (que depende del hosting/CDN, no del código).



Implementado en el código

Amenaza	Medida aplicada
XSS (inyección de scripts)	Todo el texto dinámico se escapa con <code>escapeHTML()</code> antes de insertarse en el DOM. Además, una Content-Security-Policy (CSP) restringe desde qué dominios se pueden cargar scripts, estilos e imágenes.
Clickjacking	Cabecera <code>X-Frame-Options: SAMEORIGIN + frame-ancestors</code> .
MIME sniffing	Cabecera <code>X-Content-Type-Options: nosniff</code> .
Man-in-the-middle	<code>Strict-Transport-Security (HSTS)</code> + redirección forzada a HTTPS + <code>upgrade-insecure-requests</code> .
Fuga de datos por referer	<code>Referrer-Policy: strict-origin-when-cross-origin</code> .
Manipulación del monto de pago	La firma de integridad de Wompi se genera en el servidor con un secreto. El servidor valida que el monto sea entero positivo y la moneda <code>COP</code> .
Cobros duplicados	Cada pago usa una referencia única irrepetible.
Exposición de archivos sensibles	<code>.htaccess</code> bloquea <code>.md</code> , <code>.json</code> , <code>.log</code> , backups y desactiva el listado de directorios.



Sobre “SQL Injection”

Esta web es **100% frontend estático: no tiene base de datos ni backend propio**, por lo que **no existe superficie para inyección SQL**. Los datos de productos están en un archivo JavaScript y el carrito vive en el navegador (`localStorage`).

La única pieza de servidor (opcional) es la función de firma de Wompi, que **no usa base de datos** y **valida estrictamente** sus entradas.

Si en el futuro agregas un backend con base de datos, usa **consultas parametrizadas (prepared statements)** y validación de entradas para evitar SQLi.

Protección contra DDoS (requiere activarse en el hosting)

Un ataque DDoS **no se puede frenar solo con código**; se mitiga en la capa de red/CDN.

Recomendación (gratis): **poner el dominio detrás de Cloudflare**:

1. Crea una cuenta en <https://cloudflare.com> (<https://cloudflare.com>) y agrega tu dominio.
2. Activa **“Bot Fight Mode”** y **“Under Attack Mode”** cuando lo necesites.
3. Configura **Rate Limiting** (ej: máx. 100 solicitudes/min por IP).
4. Activa el **WAF** (Web Application Firewall) con las reglas gestionadas.
5. Deja el **caché** de Cloudflare activo para servir la web sin tocar tu servidor.

El archivo `.htaccess` incluido también añade límites básicos de tamaño y tiempo de petición como primera línea de defensa.

Cabeceras según tu hosting

- **Apache / cPanel:** ya incluido en `.htaccess`.
- **Netlify / Cloudflare Pages:** archivo `_headers`.
- **Vercel:** archivo `vercel.json`.
- Como respaldo, las páginas HTML también llevan la CSP en una etiqueta `<meta>`.

Verifica tu seguridad

Tras publicar, analiza tu sitio en:

- <https://securityheaders.com> (<https://securityheaders.com>)
- <https://observatory.mozilla.org> (<https://observatory.mozilla.org>)